Building Secure Systems? Authentication, Access Control, and the Human Element in the 2021 Colonial Pipeline Ransomware Attack

[Student Name]

School of Cyber Studies, The University of Tulsa

CYB-7153-01: Foundations of Cyber Security

[Instructor Name]

[Due Date]

Building Secure Systems? Authentication, Access Control, and the Human Element in the 2021 Colonial Pipeline Ransomware Attack

Introduction

On May 7, 2021, the Colonial Pipeline Company learned that criminals had attacked its computer network with ransomware. Within hours, the company shut down its entire pipeline system, which supplies roughly half of the fuel used on the East Coast of the United States (Gatlan, 2021). For almost six days, gasoline, diesel, and jet fuel could not move from refineries on the Gulf Coast to markets in the Southeast and the Mid-Atlantic. Thousands of gas stations ran out of fuel, drivers waited in long lines, and fuel prices went up (GasBuddy, 2021; Kelly & Resnick-Ault, 2021). The company also paid the attackers a ransom in bitcoin worth about $4.4 million (Lakshmanan, 2022).

This incident is important not because the attack was technically advanced, but because it was surprisingly simple. According to the company's chief executive officer, the attackers entered the network with a single password for an old virtual private network (VPN) account that did not use multi-factor authentication (MFA) (Kelly & Resnick-Ault, 2021). In other words, one weakness in identity and access management led to one of the most disruptive cyberattacks on critical infrastructure in U.S. history. The case shows clearly that cybersecurity is not only a technical problem. It is a socio-technical problem in which technology, people, money, and law all interact.

This paper analyzes the Colonial Pipeline attack through the foundational concepts covered in the first three modules of this course: (a) the CIA triad and access control; (b) identification, authentication, and authorization; and (c) the human element of cybersecurity, including economics, psychology, and decision-making. After describing the background of the

incident, the paper examines its technical aspects, human factors, economic impact, and legal and ethical considerations. It then discusses lessons learned and ends with a conclusion.

The main argument of this paper is that the Colonial Pipeline attack was a chain of small failures rather than a single large one. A technical gap (a forgotten account without MFA) existed because of human and organizational decisions. The impact of that gap became much larger because the company was not ready to operate its pipeline without its business computer systems. Finally, the costs of these failures were paid mostly by other people, such as drivers and gas station owners, which helps to explain why the security investment was not made earlier.

Background

The Company and Its Systems

Colonial Pipeline Company is a privately owned company based in Alpharetta, Georgia. It operates a 5,500-mile pipeline system (Hawkins, 2022) that moves about 2.5 million barrels of refined fuel products per day (Lubin, 2023). The pipeline connects Gulf Coast refineries with major markets on the East Coast (Kelly & Resnick-Ault, 2021). Many areas in the Southeast have few other ways to receive fuel, so the pipeline is a clear example of critical infrastructure: if it stops, daily life and the economy are affected very quickly.

Like most pipeline operators, Colonial uses two main types of computer systems. The first is the information technology (IT) network, which supports business functions such as email, accounting, and billing. The second is the operational technology (OT) network, which includes industrial control systems that operate pumps, valves, and the flow of fuel. In this attack, the ransomware was deployed on the IT network. At the time, federal agencies reported no sign that the OT network had been directly affected (Cybersecurity and Infrastructure Security Agency [CISA] & Federal Bureau of Investigation [FBI], 2021). However, the

company's billing system was compromised, and without it Colonial could not track fuel deliveries or bill its customers (Lubin, 2023). This dependency between IT and OT is a key part of the story.

The Attackers

The FBI attributed the attack to DarkSide, a cybercrime group based in Russia (Kelly & Resnick-Ault, 2021). DarkSide used a ransomware-as-a-service (RaaS) model. In this model, one criminal group develops the ransomware and runs the infrastructure behind it, and then it rents this capability to other criminals, called affiliates, who break into victims' networks and share the profits (Parfomak & Jaikaran, 2021). This business model makes ransomware easier to scale, because the people who write the malware do not need to carry out every attack themselves (Lubin, 2023).

Warning Signs Before the Attack

The attack was not completely unexpected. In 2019, the Director of National Intelligence warned Congress that pipelines were vulnerable to cyberattacks that could shut them down for days or weeks, and in 2020 a ransomware attack had already caused a shutdown at another pipeline facility (Parfomak & Jaikaran, 2021). A 2018 Government Accountability Office report had also found weaknesses in the federal pipeline security program. Even so, the Transportation Security Administration (TSA), which is responsible for pipeline security, had not issued mandatory cybersecurity rules. Instead, it relied on voluntary guidelines (Parfomak & Jaikaran, 2021). Table 1 summarizes the main events of the incident and its aftermath.

Table 1

Timeline of the Colonial Pipeline Ransomware Attack and Its Aftermath

Date	Event
April 29, 2021	Attackers log in to Colonial's network through a legacy VPN account using a compromised password (Turton & Mehrotra, 2021).
May 6, 2021	Attackers steal about 100 GB of data in roughly two hours (Gatlan, 2021).
May 7, 2021	Ransom note is discovered; Colonial takes systems offline, stops all pipeline operations, and notifies the FBI (Gatlan, 2021; U.S. Department of Justice [DOJ], 2021).
May 8, 2021	Colonial pays a ransom in bitcoin worth about $4.4 million (Lakshmanan, 2022; DOJ, 2021).
May 9, 2021	The Federal Motor Carrier Safety Administration declares an emergency in 17 states and the District of Columbia (Gatlan, 2021).
May 11, 2021	CISA and the FBI publish Joint Cybersecurity Advisory AA21-131A on DarkSide (CISA & FBI, 2021).
May 12, 2021	Colonial begins restarting the pipeline; the President signs Executive Order 14028 (Exec. Order No. 14028, 2021).
May 2021	TSA issues Security Directive Pipeline-2021-01, the first mandatory cybersecurity rules for pipelines (U.S. Department of Homeland Security [DHS], 2021).
June 7, 2021	The Department of Justice seizes 63.7 bitcoin, worth about $2.3 million (DOJ, 2021).
June 8, 2021	Colonial's CEO testifies before the U.S. Senate (Kelly & Resnick-Ault, 2021).
July 2021	TSA issues Security Directive Pipeline-2021-02 (DHS, 2021).
August 2021	Colonial notifies 5,810 people that their personal data was stolen (Gatlan, 2021).
May 2022	PHMSA proposes a civil penalty of $986,400 (Lakshmanan, 2022).
July 2022	A federal court in Georgia dismisses a gas station's proposed class action (Hawkins, 2022).

Note. Compiled from the sources cited in each row.

Technical Analysis

Initial Access: A Forgotten VPN Account

The attack vector was simple. Investigators from the security firm Mandiant found that the attackers first logged in to Colonial's network on April 29, 2021, through a VPN account that was no longer in use but had never been disabled (Turton & Mehrotra, 2021). A VPN gives remote users an encrypted connection into a company's internal network, so it is a powerful entry point. The password for this account was later found in a batch of leaked passwords on the dark web, which suggests that it may have been reused on another service that was breached (Turton & Mehrotra, 2021). In his Senate testimony, the CEO explained that this legacy VPN used only single-factor authentication. He also stressed that the password was complex and not easy to guess (Kelly & Resnick-Ault, 2021). The company said it still did not know exactly how the attackers obtained the credentials (“Colonial Pipeline CEO,” 2021).

In the MITRE ATT&CK framework, which CISA and the FBI used to describe DarkSide's behavior (CISA & FBI, 2021), this type of entry is known as the use of *valid accounts* through *external remote services*. The important point is that the attackers did not exploit a software bug. They did not need to. From the system's point of view, they were a legitimate user with a correct username and password. This is why authentication weaknesses are so dangerous: when the only proof of identity is a secret, anyone who knows the secret becomes that user.

Attack Progression and Malware Characteristics

After gaining access, the attackers moved through the IT network and prepared a double extortion attack. On May 6, 2021, they stole about 100 GB of data in roughly two hours (Gatlan, 2021). On May 7, they deployed the DarkSide ransomware, which encrypted files and left a

ransom note. In a double extortion attack, the criminals both lock the victim's systems and threaten to publish the stolen data if the ransom is not paid, so the victim is pressured twice (Parfomak & Jaikaran, 2021).

DarkSide ransomware used a combination of the Salsa20 and RSA encryption algorithms (Gatlan, 2021). In this common design, a fast symmetric cipher (Salsa20) encrypts the files, and a public-key algorithm (RSA) protects the symmetric keys. As a result, the victim cannot recover the files without the attackers' private key. According to the joint advisory, DarkSide affiliates typically used tools such as Cobalt Strike for command and control and sometimes used anonymization services like Tor. For this reason, the advisory recommended blocking unexpected Tor connections and detecting post-exploitation tools (CISA & FBI, 2021).

Technical Impact on the CIA Triad

The CIA triad of confidentiality, integrity, and availability, which was introduced in Module 1, is a useful way to describe the technical impact. Confidentiality was lost when the attackers stole about 100 GB of company data, including personal information about 5,810 people (Gatlan, 2021). Integrity was damaged because files were encrypted and the company could no longer trust that its systems were clean or that its billing records were correct. Availability was the most visible loss. First, IT systems became unavailable because of the encryption. Second, and more importantly, the pipeline itself became unavailable because the company decided to shut it down.

This second point deserves attention. The ransomware did not directly stop the pumps, but the physical flow of fuel still stopped. The shutdown was partly a safety precaution, because the company could not be sure how far the attackers had gone. It was also partly a business necessity, because the company could not bill for fuel without its IT systems (Lubin, 2023). The

case therefore shows that network segmentation between IT and OT is necessary but not sufficient. If business processes depend on IT systems, an attack on IT can still cause a loss of availability in the physical world.

Countermeasures: What Was Missing and What Could Have Helped

Some security controls were in place. The VPN encrypted remote connections, the password met complexity rules, and the OT network does not appear to have been infected, which suggests that some separation between IT and OT existed. However, several important countermeasures were missing or weak.

The first and most obvious missing control was MFA. The very first mitigation in the CISA and FBI advisory is to require MFA for remote access to both IT and OT networks (CISA & FBI, 2021). With MFA, the stolen password alone would not have been enough. The second missing control was account lifecycle management. An account that is no longer needed should be disabled immediately. This follows the principle of least privilege and the principle of fail-safe defaults described by Saltzer and Schroeder (1975): by default, access should be denied unless there is a clear reason to allow it. The third weakness was detection. A transfer of 100 GB of data in two hours is unusual, and monitoring tools could have raised an alert before the ransomware was deployed.

Other countermeasures would have reduced the impact even if the attackers got in. The joint advisory stressed strong segmentation between IT and OT, regular testing of manual controls so that critical functions can continue if systems must be taken offline, and backups that are tested and kept separate from the network (CISA & FBI, 2021). Researchers have also recommended a zero-trust model, in which no user or device is trusted automatically just because it is inside the network, as well as stronger user authentication (Beerman et al., 2023). Finally, as

discussed later, federal regulators concluded that Colonial had not adequately planned for a manual shutdown and restart of its pipeline, which made the outage longer (Lakshmanan, 2022).

Human Factors

Human Error and the Question of Social Engineering

In many incidents, human error means that one employee clicked on a malicious link. The Colonial case is different. There is no public evidence that the attack started with phishing, and the company said it did not know how the password was stolen ("Colonial Pipeline CEO," 2021). The human errors in this case were mostly organizational. Someone created a VPN profile, stopped using it, and nobody disabled it. The organization also allowed at least one remote access path to exist without MFA. In addition, the appearance of the password in a leaked database suggests that the account owner may have reused it elsewhere (Turton & Mehrotra, 2021).

Social engineering cannot be ruled out, because DarkSide affiliates were known to use spearphishing, and the joint advisory recommended user training and simulated phishing exercises (CISA & FBI, 2021). However, the more important lesson is that the attackers did not need to trick anyone on the day of the attack. They only needed a secret that had already leaked. This shows that a strong security culture must include not only employee awareness but also administrative discipline, such as regular reviews of who has access to what.

Psychological Factors

Several psychological factors help to explain why this weakness existed. The first is the burden of password management. People have many accounts and cannot remember a different complex password for each one, so they often reuse passwords. Herley (2009) argued that users who ignore security advice are often acting rationally, because the time and effort required by the

advice seem larger than the benefit they can see. From this perspective, password reuse is a predictable result of poor system design, not simply a personal failure.

The second factor is a false sense of security. During his testimony, the CEO emphasized that the password was complex (Kelly & Resnick-Ault, 2021). This reflects a common misunderstanding: complexity protects a password against guessing, but it offers no protection once the password itself has been stolen. The third factor is the “out of sight, out of mind” problem. A forgotten account creates no daily inconvenience, so no one feels an urgent need to remove it. Together with optimism bias, which is the tendency to believe that rare and serious events will not happen to us, this makes it easy for organizations to postpone security work.

Psychology also shaped the response to the attack. The decision to pay the ransom was made quickly, under high stress and great uncertainty about what the attackers had done. The CEO later defended the payment before the Senate as the right choice for restoring fuel supply, although some senators questioned whether the company should have consulted the government first (Kelly & Resnick-Ault, 2021). Among the public, fear of shortages led to panic buying, which made the shortages worse. On May 14, 2021, about 88% of gas stations in Washington, DC, and about 65% of stations in North Carolina had no fuel (GasBuddy, 2021), even though the pipeline had already restarted. This is a clear example of how human reactions can multiply the effects of a technical incident.

Impact on Individuals and Society

The attack violated the privacy of 5,810 individuals whose personal information was stolen. The exposed records included names, contact information, dates of birth, government-issued identification numbers such as Social Security and driver's license numbers, and health-related information, including health insurance details (Gatlan, 2021). These data can be used for

identity theft and fraud for many years. Notably, the affected people were told about the breach only in August 2021, about three months after the data was stolen (Gatlan, 2021).

The social consequences were even wider. The Federal Motor Carrier Safety Administration declared an emergency in 17 states and the District of Columbia so that fuel could be moved by truck more easily (Gatlan, 2021). People could not get fuel to go to work, to travel, or to run their businesses. The Department of Energy led the federal response because the incident affected national energy supplies (Parfomak & Jaikaran, 2021). Perhaps most importantly, the attack damaged public trust, because it showed ordinary citizens that a criminal group on the other side of the world could interrupt a basic service with little more than a stolen password.

Economic Impact

Direct Costs to Colonial Pipeline

The most visible direct cost was the ransom of about $4.4 million (Lakshmanan, 2022). About a month later, the Department of Justice seized 63.7 bitcoin from the attackers. This was the majority of the bitcoin that Colonial had paid, but because the price of bitcoin had fallen, it was worth only about $2.3 million (DOJ, 2021). As a result, even after the recovery, Colonial's net loss on the ransom itself was roughly $2 million.

The ransom, however, was only a part of the total cost. Colonial also had to pay for incident response experts, legal advice, system restoration, and new security controls, although the company has not published a full figure for these costs. The company also lost revenue while the pipeline was not operating. Since the pipeline normally moves about 2.5 million barrels of product per day (Lubin, 2023), a shutdown of almost six days means that, by a rough estimate, around 15 million barrels of fuel deliveries were delayed. Later, the Pipeline and Hazardous

Materials Safety Administration (PHMSA) proposed a civil penalty of $986,400 for control room management failures (Lakshmanan, 2022). In addition, the company had to defend itself against lawsuits (Hawkins, 2022), and it offered credit monitoring to the people whose data was stolen. Its reputation suffered as well, because its security failures were discussed in Congress and in national media.

Indirect Costs and Broader Economic Effects

Many of the largest costs were paid by others. Gas stations lost sales when their pumps ran dry, and a proposed class action was filed on behalf of more than 11,000 stations (Hawkins, 2022). Consumers paid higher prices and lost time waiting in lines. Trucking companies, airlines, and other businesses that depend on fuel had to change their operations. Governments at several levels had to spend resources on the emergency response.

The attack also had effects on the wider market for cybercrime and cybersecurity. Paying a ransom provides income and motivation for criminal groups, and some researchers argue that Colonial's payment created an incentive for similar attacks (Beerman et al., 2023). On the other hand, the government's response increased the costs for attackers. The Justice Department stated that its goal was to make ransomware attacks “more costly and less profitable” (DOJ, 2021), and the State Department offered a reward of up to $10 million for information about DarkSide's leaders (Lubin, 2023). Soon after the attack, DarkSide shut down, and its successor group, BlackMatter, said that it would not attack oil and gas infrastructure (Gatlan, 2021). This suggests that criminals also make cost-benefit decisions and that raising their risk can change their behavior.

An Economic Explanation: Externalities and Misaligned Incentives

Module 3 introduced the idea that many security failures are caused by poor incentives rather than by a lack of technology. Anderson (2001) argued that information security often fails because the party who is able to protect a system is not the party who suffers most when it fails. The Colonial case fits this idea very well. MFA and account reviews are not expensive technologies. However, before the attack, the full cost of a pipeline shutdown was not paid by Colonial alone. Instead, it was spread across millions of drivers, thousands of businesses, and the government. In economic terms, this is a negative externality.

The legal outcome of the gas station lawsuit supports this analysis. The court found that Colonial did not have a legal duty to guarantee continuous fuel service to the gas station (Hawkins, 2022). In other words, the law did not require the company to pay for the harm its security failure caused to others. When a company does not bear the full cost of a failure, it has a weaker reason to invest in preventing it. This economic reasoning is one of the strongest arguments for the mandatory regulations that followed the attack.

Legal and Ethical Considerations

Legal and Regulatory Frameworks

Several legal frameworks applied to the incident. The TSA had authority over pipeline security under laws passed in 2001 and 2007, but it had never issued binding cybersecurity regulations for pipelines (Parfomak & Jaikaran, 2021). PHMSA, part of the Department of Transportation, enforces pipeline safety rules, including rules on how control rooms must plan for emergencies (Lakshmanan, 2022). State data breach notification laws required Colonial to inform the people whose personal information was stolen, which it did through notification letters (Gatlan, 2021). Finally, the attackers' actions were federal crimes involving computer

intrusion and money laundering, which gave the Justice Department the legal basis to seize the ransom proceeds (DOJ, 2021).

Legal and Policy Responses

The response to the attack was fast and wide. Colonial notified the FBI quickly, and the Justice Department later praised this early notification. By following the payment on the public Bitcoin ledger, investigators were able to find a wallet for which the FBI had the private key and to seize the funds under a court warrant (DOJ, 2021). On May 12, 2021, while the pipeline was still being restarted, the President signed Executive Order 14028, *Improving the Nation's Cybersecurity*. The order required federal agencies to adopt MFA and encryption, to move toward a zero-trust architecture, and to improve incident response (Exec. Order No. 14028, 2021). Although the order focused mainly on the federal government, it showed that the government now treated these basic controls as essential.

More direct changes came for pipelines. In May 2021, the TSA issued Security Directive Pipeline-2021-01, which required critical pipeline operators to report cybersecurity incidents to CISA, to name a cybersecurity coordinator available at all times, and to review their security practices and report gaps within 30 days. In July 2021, a second directive required specific protections against ransomware, a cybersecurity contingency and recovery plan, and a review of cybersecurity architecture (DHS, 2021). These directives ended the long period of purely voluntary guidelines. In 2022, Congress also passed the Cyber Incident Reporting for Critical Infrastructure Act, which requires covered critical infrastructure entities to report substantial cyber incidents to CISA within 72 hours and ransom payments within 24 hours, once CISA's implementing rules take effect (Cyber Incident Reporting for Critical Infrastructure Act of 2022, 2022).

Colonial itself faced legal consequences. In May 2022, PHMSA proposed a penalty of $986,400. The regulator said that inspections carried out in 2020, before the attack, had found that Colonial had not adequately planned for a manual shutdown and restart of the pipeline, and that this failure contributed to the national impact of the outage (Lakshmanan, 2022). Private lawsuits were less successful. A gas station in North Carolina filed a proposed class action claiming that Colonial had failed to protect its systems, but a federal court in Georgia dismissed the claims in 2022 (Hawkins, 2022).

Ethical Implications

The attack raises several ethical questions about responsibility, accountability, and harm. The primary moral responsibility clearly belongs to the criminals who planned and carried out the attack for profit. However, a company that operates critical infrastructure also has a special responsibility toward the public, because many people depend on its services and cannot easily choose another provider. The court's decision shows that this responsibility is not always a legal duty. This gap between what the law requires and what ethics expects is one of the most interesting aspects of the case.

The ransom payment is a classic ethical dilemma. From a consequentialist point of view, paying might be justified if it helped to restore fuel supply faster and reduced harm to millions of people. From a rule-based or duty-based point of view, paying is problematic because it rewards criminals, funds future attacks, and may encourage attacks on other victims (Beerman et al., 2023). The fact that senators questioned the decision (Kelly & Resnick-Ault, 2021) shows that there is no easy answer.

The decision to shut down the pipeline also has an ethical side. The company presented the shutdown as a precaution to protect the public. Lubin (2023), however, argues that the

company's inability to bill customers played a central role, which suggests that business interests and public interests were closely mixed. Finally, there is a question of transparency and fairness toward employees and other individuals whose data was stolen, since they learned about the breach several months later. Taken together, these issues show that ethical cybersecurity is not only about avoiding harm, but also about being honest, prepared, and accountable when harm happens.

Lessons Learned

The Colonial Pipeline attack offers lessons that connect directly to each of the first three modules of this course.

Module 1: The CIA Triad and Access Control

First, availability deserves special attention in critical infrastructure. Many organizations focus on confidentiality, but for a pipeline, the most serious harm comes from the loss of availability. Second, access control must cover every entry point, including old and forgotten ones. A single unused account was enough to defeat the organization's other defenses. Applying least privilege and fail-safe defaults (Saltzer & Schroeder, 1975) means that access should be removed when it is no longer needed and that remote access should be limited to what each user truly requires. Third, the case shows that separating IT and OT is not enough if business operations still depend on IT. Organizations must understand these dependencies and plan how to keep critical functions available when IT systems are down (CISA & FBI, 2021).

Module 2: Identification, Authentication, and Authorization

The attack was, at its core, an identity failure. For identification, every account should have a known owner and a clear purpose, and organizations should regularly review their accounts to find ones that are orphaned or unused. For authentication, the case proves that a

strong password is not the same as strong authentication. A password is only something you know, and once it leaks, it no longer proves anything. Adding a second factor, such as something you have (a hardware token or mobile authenticator), would likely have stopped this attack (CISA & FBI, 2021). For authorization, organizations should limit what a remote VPN user can reach, so that one compromised account cannot give access to large parts of the network. Finally, logging and monitoring support accountability and can detect unusual behavior, such as a large data transfer, before serious damage occurs.

Module 3: Economics, Psychology, and Decision-Making

From an economic perspective, the case shows why market forces alone may not produce enough security for critical infrastructure. When the costs of a failure fall mainly on third parties, companies tend to underinvest (Anderson, 2001). Regulation such as the TSA directives and mandatory incident reporting helps to correct this problem by making companies responsible for basic protections. From a psychological perspective, security controls should be designed for real human behavior. Organizations should reduce the burden of password management, for example by using single sign-on with MFA or password managers, instead of relying on users to follow advice that is difficult to follow (Herley, 2009). They should also communicate clearly with the public during a crisis to reduce panic buying.

From a decision-making perspective, the most difficult decisions, such as whether to pay a ransom or shut down operations, should not be made for the first time in the middle of a crisis. Organizations should prepare incident response plans, test manual operating procedures, and practice with tabletop exercises. PHMSA's findings show that Colonial's lack of preparation for manual operations made the outage longer (Lakshmanan, 2022). Finally, the quick recovery of part of the ransom shows the value of early cooperation with law enforcement (DOJ, 2021).

Conclusion

The Colonial Pipeline ransomware attack is one of the most important cybersecurity incidents of recent years. It began with a basic weakness: a forgotten VPN account protected only by a password that had already leaked. Because MFA was missing and the account had never been disabled, the attackers were able to enter the network, steal data, and deploy ransomware. The technical damage was limited to the IT network, but the company's dependence on those systems and its lack of preparation for manual operations turned an IT incident into a regional fuel crisis.

This analysis has shown that the incident cannot be understood through technology alone. The concepts of the CIA triad and access control explain why availability and forgotten entry points matter. The concepts of identification, authentication, and authorization explain exactly how the attackers got in and how MFA and account management could have stopped them. The human element, including economics, psychology, and decision-making, explains why these simple protections were missing, why the public reacted with panic, and why the costs of the failure fell on so many people outside the company.

The attack also changed the policy landscape. It led to the first mandatory cybersecurity rules for U.S. pipelines, contributed to new federal incident reporting requirements, and showed that governments can raise the costs of ransomware for criminals. For the future of cybersecurity, the main message is clear: the most dangerous vulnerabilities are often not complex technical flaws, but basic weaknesses that remain because of human, organizational, and economic factors. Protecting critical infrastructure therefore requires good technology, careful design for human behavior, sensible incentives, and preparation for the day when defenses fail.

References

Anderson, R. (2001). Why information security is hard: An economic perspective. In *Proceedings of the 17th Annual Computer Security Applications Conference* (pp. 358–365). IEEE. https://doi.org/10.1109/ACSAC.2001.991552

Anthropic. (2026). *Claude* (Opus 5 version) [Large language model]. https://claude.ai

Beerman, J., Berent, D., Falter, Z., & Bhunia, S. (2023). A review of Colonial Pipeline ransomware attack. In *2023 IEEE/ACM 23rd International Symposium on Cluster, Cloud and Internet Computing Workshops (CCGridW)* (pp. 8–15). IEEE. https://doi.org/10.1109/CCGridW59191.2023.00017

Colonial Pipeline CEO: Ransomware attack started via pilfered ‘legacy’ VPN account. (2021, June 8). *Dark Reading*. https://www.darkreading.com/cyberattacks-data-breaches/colonial-pipeline-ceo-ransomware-attack-started-via-pilfered-legacy-vpn-account

Cyber Incident Reporting for Critical Infrastructure Act of 2022, Pub. L. No. 117-103, div. Y, 136 Stat. 1038 (2022).

Cybersecurity and Infrastructure Security Agency & Federal Bureau of Investigation. (2021, May 11). *DarkSide ransomware: Best practices for preventing business disruption from ransomware attacks* (Joint Cybersecurity Advisory AA21-131A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a

Exec. Order No. 14028, 86 Fed. Reg. 26633 (2021). https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity

GasBuddy. (2021, May). *Colonial Pipeline shutdown: Fuel outages by state*. https://www.gasbuddy.com/go/colonial-pipeline-shutdown-fuel-outages-by-state

Gatlan, S. (2021, August 16). Colonial Pipeline reports data breach after May ransomware attack. *BleepingComputer*. https://www.bleepingcomputer.com/news/security/colonial-pipeline-reports-data-breach-after-may-ransomware-attack/

Hawkins, S. (2022, July 11). Colonial Pipeline beats gas station's ransomware shutdown claims. *Bloomberg Law*. https://news.bloomberglaw.com/privacy-and-data-security/colonial-pipeline-beats-gas-stations-ransomware-shutdown-claims

Herley, C. (2009). So long, and no thanks for the externalities: The rational rejection of security advice by users. In *Proceedings of the 2009 New Security Paradigms Workshop* (pp. 133–144). ACM. https://doi.org/10.1145/1719030.1719050

Kelly, S., & Resnick-Ault, J. (2021, June 9). Hackers only needed a single password to disrupt Colonial Pipeline, CEO testifies. *Insurance Journal*. https://www.insurancejournal.com/news/national/2021/06/09/617870.htm

Lakshmanan, R. (2022, May 10). U.S. proposes $1 million fine on Colonial Pipeline for safety violations after cyberattack. *The Hacker News*. https://thehackernews.com/2022/05/us-proposes-1-million-fine-on-colonial.html

Lubin, A. (2023). Cyber plungers: Colonial Pipeline and the case for an omnibus cybersecurity legislation. *Georgia Law Review, 57*(4), Article 4. https://digitalcommons.law.uga.edu/glr/vol57/iss4/4

Parfomak, P. W., & Jaikaran, C. (2021). *Colonial Pipeline: The DarkSide strikes* (CRS Insight No. IN11667). Congressional Research Service. https://crsreports.congress.gov/product/pdf/IN/IN11667

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Turton, W., & Mehrotra, K. (2021, June 4). Hackers breached Colonial Pipeline using compromised password. *Bloomberg*. https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password

U.S. Department of Homeland Security. (2021, July 20). *DHS announces new cybersecurity requirements for critical pipeline owners and operators* [Press release]. https://www.dhs.gov/news/2021/07/20/dhs-announces-new-cybersecurity-requirements-critical-pipeline-owners-and-operators

U.S. Department of Justice. (2021, June 7). *Department of Justice seizes $2.3 million in cryptocurrency paid to the ransomware extortionists Darkside* [Press release]. https://www.justice.gov/archives/opa/pr/department-justice-seizes-23-million-cryptocurrency-paid-ransomware-extortionists-darkside

Appendix

Statement on the Use of Artificial Intelligence

[Edit this statement so that it accurately describes how you used AI.] In preparing this paper, the author used Claude (Anthropic, 2026), a large language model, to help research, organize, and draft the text. The author reviewed and revised the content, checked the facts against the cited sources, and takes full responsibility for the final paper.